

credential_scan

credential_scan.sh — git-hook credential-leak guard

Revision: 2 Last modified: 2026-06-16T19:45:00Z

Overview

scripts/git_hooks/credential_scan.sh is the shared scanner behind the project's local pre-commit and pre-push git hooks. It implements the §11.4.10.A clause 5 mandate to catch **inline secret-shaped literals** mechanically — the class that .gitignore (which only covers secret *files*) cannot stop. It is the §11.4.75 Layer-1 (pre-commit) and Layer-3 (pre-push) credential guard.

Forensic origin: an SSH password literal (WhiteSnake<REDACTED-§11.4.10>) reached the tracked tree across 20 text occurrences AND 6 compiled binaries because no commit/push-time grep existed (see docs/qa/secret_scrub_20260616T143748Z/PLAN.md).

Prerequisites

- bash, git, grep, perl on PATH.

Usage

Install the hooks (idempotent):

```
bash scripts/install_git_hooks.sh
```

Scan staged content (what pre-commit runs):

```
bash scripts/git_hooks/credential_scan.sh --staged
```

Scan specific working-tree files (what pre-push runs per changed file):

```
bash scripts/git_hooks/credential_scan.sh path/to/file.sh
```

Exit 0 = clean; exit 1 = a credential-shaped literal was found (file:line printed, value MASKED — the scanner never prints the secret).

Pattern set (closed; extend deliberately)

1. Historical leaked-class token shape WhiteSnake<digits>.
2. Inline -password[=]"?<literal> where the value is NOT \${VAR} / \$env(VAR) / empty / a <redacted...> marker / a placeholder.
3. *_PASS/*_PASSWORD/Password: = "<literal>" with a non-env, non-empty value.
4. Common provider API-key shapes: sk-..., AKIA..., ghp_..., xox[baprs]-....

Edge cases / honest boundaries

- Env-ref values (\${SSH_WORKER_PASSWORD}, \$env(SSH_WORKER_PASSWORD)) PASS — they are the sanctioned scrub form.
- HTML-escaped redaction/placeholder markers (<redacted...>, any <...>) PASS — committed .html exports of review/QA docs escape the literal <redacted...> markers, and those escaped forms are exempt exactly like their literal counterparts (Rev 2, 2026-06-16: closes a false-positive where REVIEW.html documenting the REMOTE_PASS="<redacted-per-§11.4.10>" pattern was flagged). Guarded permanently by scripts/testing/test_credential_scan.sh (§11.4.135).
- constitution/, scripts/git_hooks/, scripts/testing/test_credential_scan.sh, this doc, and docs/qa/secret_scrub_* are ignore-listed because they legitimately document / test the pattern class (the regression test MUST contain fixture literals that the scanner flags, so it is exempt exactly like the hook source).
- The scanner catches the enumerated shapes, NOT every conceivable secret encoding (e.g. base64-wrapped blobs). It is one strong layer, not a guarantee of zero leaks.

Related scripts

- scripts/git_hooks/pre-commit, scripts/git_hooks/pre-push — the hook entry points.
- scripts/install_git_hooks.sh — idempotent installer.
- scripts/testing/test_credential_scan.sh — permanent regression guard (§11.4.135): pins the HTML-escaped-redaction false-positive (A) and the real-leak false-negative (B).

Last verified

2026-06-16 (Rev 2) — anti-bluff: scripts/testing/test_credential_scan.sh GREEN (7/7); §1.1 mutation (revert the <...> exemption) makes the false-positive guard FAIL and restore returns GREEN. Scanner still FAILs on a real REMOTE_PASS="<literal>" and PASSES on env-ref/empty/<redacted...>/<redacted...> forms.